KnowledgeOS Enterprise Test Data — Vendor Management & Procurement Policy

Field	Value
Version	3.2
Classification	INTERNAL - PROCUREMENT, LEGAL, FINANCE, SECURITY
Effective Date	February 1, 2024
Last Reviewed	January 15, 2024
Document Owner	Chief Procurement Officer / General Counsel
Review Cycle	Annual
Regulatory References	SOX 404, FCPA, UK Bribery Act, GDPR Art. 28, SOC 2 CC9, NIST 800-161

---

1. Purpose & Scope

This policy governs the end-to-end vendor lifecycle at TechGlobal Solutions Inc. ("Company"), from sourcing through offboarding. It ensures vendors are selected fairly, contracted properly, managed for performance and risk, and exited securely.

Applies to: All purchases of goods/services > $0 (no threshold exceptions).

Excludes: Employee expense reimbursements (see Expense Policy), M&A (Corp Dev).

2. Governance & Authority

2.1 Approval Thresholds (Total Contract Value - TCV)

TCV Range	Approvers Required	Process
$0 – $5,000	Requestor + Manager	P-Card / PO

$5,001–25,000	Requestor + Manager + Director	Competitive Quote (3)
$25,001–100,000	Requestor + Manager + Director + VP + Finance	RFP (3+ bids)
$100,001–500,000	Above + CFO + Legal	Formal RFP
$500,001–1M	Above + CEO	Formal RFP + Board
> $1M	Above + Board Approval	Formal RFP + Board

- Splitting purchases to avoid thresholds: PROHIBITED (audit flag)
- Emergency: VP+ verbal + written within 24 hrs + ratification at next threshold

2.2 Roles & Responsibilities

- Requestor: Business need, requirements, stakeholder alignment
- Procurement: Sourcing, negotiation, contract execution, vendor management
- Legal: Contract review, risk allocation, compliance, IP, data protection
- Finance: Budget validation, payment terms, tax, accounting treatment
- Security: Vendor risk assessment (all vendors with data/system access)
- Privacy: DPA review, transfer mechanism, privacy assessment (data processors)
- IT/Engineering: Technical requirements, integration, architecture review

3. Vendor Tiering & Risk Classification

3.1 Tier Definitions (Determines Due Diligence Depth)

Tier	Criteria (Any One)	Examples	Assessment Frequency
1	Access to RESTRICTED data OR production systems OR critical business continuity dependency	Cloud, SaaS (core), Payroll, HRIS (Workday, Salesforce, AWS)	Initial + Annual
2	Access to CONFIDENTIAL data OR internal systems OR significant spend (> $100K/yr)	Marketing tools, Analytics, Monitoring, ATS	Initial + Biennial
3	No data access OR low risk commodity AND spend < $100K/yr	Office supplies, Travel, Catering, Swag	Initial only

3.2 Risk Scoring (Tier 1/2 Only)

- Financial: D&B score, revenue trend, insurance, litigation
- Operational: SLA history, incident history, BC/DR maturity
- Security: Questionnaire (SIG Lite/Full), certifications, pen test, breach history
- Privacy: DPA, transfer mechanism, DPIA, subprocessors
- ESG: Diversity, sustainability, labor practices, sanctions screening
- Score: 1-5 per domain → Weighted composite → Risk Rating (Low/Medium/High/Critical)

4. Sourcing & Selection

4.1 Competitive Requirements

- $5K–25K: 3 written quotes (email acceptable)
- $25K–100K: Formal RFQ (Procurement manages)
- > $100K: Formal RFP (Procurement + Cross-functional evaluation team)
- Sole Source: Only with documented justification + CFO approval
  - Justification: Unique capability, emergency, standardization, regulatory

4.2 Evaluation Criteria (Weighted)

Criterion	Weight	Notes
Technical Fit	30%	Requirements traceability matrix
Total Cost of Ownership	25%	3-year TCO (license, impl, support)
Security & Privacy	20%	Tier-based assessment score
Vendor Viability	10%	Financial, roadmap, references
Contract Terms	10%	Liability, IP, termination, SLA
ESG / Diversity	5%	Certified diverse spend tracked

4.3 Diversity & Inclusion

- Target: 15% addressable spend with certified diverse suppliers (MBE/WBE/VBE/LGBTBE/DOBE)

- Tier 1/2: Diverse supplier inclusion in RFP long-list (procurement validates)
- Reporting: Quarterly to CFO + Board ESG Committee

5. Contracting

5.1 Standard Contract Templates (Legal Owned)

- MSA + SOW/Order Form (preferred)
- SaaS Addendum (data, security, SLA, IP)
- Professional Services Agreement
- Hardware/Equipment Purchase
- Staff Augmentation / Contingent Workforce
- NDAs (Mutual / One-way)

5.2 Mandatory Clauses (All Contracts)

- Data Protection: DPA (GDPR Art. 28) + SCCs + Subprocessor flow-down
- Security: Compliance with Company security standards, breach notification (24 hrs), audit rights
- IP: Company owns deliverables; vendor retains pre-existing IP (licensed)
- Liability: Cap at 2x annual fees (Tier 1: uncapped for data breaches/gross negligence)
- Indemnification: IP infringement, data breach, third-party claims
- Termination: Convenience (30-90 days), Cause (immediate), Insolvency
- Transition: 90-day transition assistance (Tier 1: 180 days)
- Insurance: Cyber (5M), E&O (5M), General Liability ($2M), Workers' Comp
- Compliance: Anti-corruption, export controls, sanctions, modern slavery
- Audit Rights: Annual (Tier 1), upon incident, regulatory request
- Governing Law: Delaware (US) / England (UK) / Singapore (APAC) — per entity

5.3 Negotiation Guardrails

- Liability cap: Never below 1x fees; Tier 1 data breach carve-out non-negotiable
- Indemnity: Mutual preferred; Company indemnity only for IP infringement
- Termination for convenience: Max 90 days notice (Tier 1: 180 days)
- Auto-renewal: PROHIBITED without explicit opt-out clause (30 days prior)
- Payment terms: Net 45 standard; Net 60 only with CFO approval; No prepay > 25%

5.4 Contract Repository

- Ironclad (CLM): All executed contracts, amendments, SOWs
- Metadata: Tier, owner, renewal date, value, risk rating, DPA status
- Alerts: 90/60/30 day renewal; 180 day auto-renewal opt-out

6. Vendor Onboarding

6.1 Onboarding Checklist (Procurement Owned)

1. Vendor Master Data: Legal name, address, tax ID, banking, contacts
2. Risk Assessment: Completed + approved (Security + Privacy sign-off for Tier 1/2)
3. Contract: Executed in Ironclad + PDF in vendor folder
4. Insurance: COI collected + verified (expiry tracking)
5. Access Provisioning: Least privilege, time-bound, documented (ServiceNow)
6. Communication: Kickoff, SLA review, escalation contacts, reporting cadence
7. Systems: Coupa (PO/Invoice), Okta (SSO/SCIM), Security tools (integration)

6.2 Contingent Workforce (Staff Aug)

- MSA with approved vendors only (preferred panel: 5 firms)
- Requisition: Hiring Manager + Finance + Procurement approval
- Rate Card: Pre-negotiated by role/level/geo
- Conversion: 6-month temp-to-perm window; conversion fee per MSA
- Compliance: I-9, E-Verify, background check (vendor responsibility)

7. Vendor Performance Management

7.1 KPIs & SLAs (Per Contract)

- Availability: 99.9% (Tier 1 SaaS), 99.5% (Tier 2)
- Support: Response times (Critical: 1 hr, High: 4 hr, Med: 1 day, Low: 5 days)
- Quality: Defect rates, CSAT, NPS
- Security: Patch SLAs, vulnerability remediation, audit findings closure
- Privacy: DSR support, breach notification, DPIA cooperation

7.2 Quarterly Business Reviews (QBRs)

- Tier 1: Quarterly (Executive sponsor + Vendor exec)
- Tier 2: Semi-annual (Vendor Manager + Vendor PM)

- Agenda: Scorecard, roadmap, risks, contract health, innovation, cost optimization

7.3 Scorecard & Remediation

- Monthly automated scorecard (Coupa + integrations)
- Red (2+ missed SLAs): 30-day remediation plan
- Yellow (1 missed SLA): Root cause + corrective action
- Green: On track
- Chronic underperformance: Escalation → Contract remedies → Replacement planning

8. Vendor Risk Monitoring (Continuous)

8.1 Monitoring Sources

- Financial: D&B alerts, bankruptcy filings, lien/UCC searches
- Security: Continuous monitoring (SecurityScorecard, BitSight, UpGuard)
- News/Regulatory: Owler, LexisNexis, sanctions lists (OFAC, EU, UN)
- Operational: Support ticket trends, SLA breaches, incident involvement
- Subprocessors: Change notifications (Tier 1: prior approval required)

8.2 Annual Reassessment (Tier 1/2)

- Updated questionnaire (SIG Lite/Full)
- Latest certifications (SOC 2 Type 2, ISO 27001, PCI, HITRUST)
- Pen test summary (redacted) or attestation
- Incident history review
- Financial health update
- Subprocessor list validation

8.3 Concentration Risk

- Single vendor > 20% category spend: Mitigation plan required
- Critical dependency (no viable alternative): Business continuity plan
- Geographic concentration: Assessed for geopolitical risk

9. Contract Renewal & Extension

9.1 Renewal Process (Starts 180 Days Pre-Expiry)

- 180 days: Procurement initiates; confirms business need with stakeholder

- 120 days: Market benchmark (pricing, alternatives)
- 90 days: Negotiation (leverage: usage data, competition, budget)
- 60 days: Legal review + approvals
- 30 days: Execution + communication
- Auto-renewal: Blocked by system; requires affirmative renewal

9.2 Renewal Levers

- Volume discounts, multi-year commitments (3-5 yr for strategic)
- Price caps (CPI + 1% max annual increase)
- Enhanced SLAs, additional features, extended support
- Co-terming: Align expiration dates for portfolio management

10. Vendor Offboarding

10.1 Offboarding Triggers

- Contract expiration (non-renewal)
- Termination for cause/convenience
- Vendor bankruptcy/acquisition
- Service migration (insourcing, alternative vendor)

10.2 Offboarding Process (90-Day Minimum for Tier 1)

Phase	Timeline	Activities
Notification	Day 0	Formal notice; transition plan kickoff; legal hold if disputed
Transition	Day 1-60	Data export/migration; knowledge transfer; access reduction
Validation	Day 60-85	Verify data completeness; test new vendor/insourced solution
Cutover	Day 85-90	Final switch; access revocation; service termination
Closeout	Day 90+	Final invoice; certificate of data destruction; lessons learned

10.3 Data Return & Destruction

- Vendor returns/destroys ALL Company data (including backups, archives, logs)
- Certificate of Destruction: Signed by vendor officer, notarized for Tier 1

- Verification: Sample audit (Tier 1); automated attestation (SaaS API)
- Subprocessors: Flow-down enforcement confirmed

10.4 Access Revocation

- Immediate: VPN, SSH, API keys, SaaS accounts, physical badges
- ServiceNow workflow: Automated + manual verification
- Audit: Post-offboarding access review (30 days)

11. Procurement Operations

11.1 Purchase Orders (POs)

- Required for all spend > $5,000 (except P-Card, recurring SaaS)
- Three-way match: PO → Receipt/Service Entry → Invoice
- Non-PO invoices: Rejected (exception: utilities, taxes, government fees)

11.2 P-Card Program

- Limit: $5,000/transaction$,25,000/month (Director+ higher)
- Allowed: Travel, low-value supplies, urgent needs, vendor onboarding
- Prohibited: Recurring services, capital equipment, restricted categories
- Reconciliation: Monthly in Concur (see Expense Policy)

11.3 Invoice Processing

- Submission: Supplier portal (Coupa) or email (invoices@techglobal.com)
- Terms: Net 45 from valid invoice receipt (not invoice date)
- Early pay discount: 2/10 Net 45 captured automatically
- Disputes: 10-day hold; resolution per contract dispute clause

11.4 Spend Analytics & Savings

- Quarterly spend cube (category, vendor, BU, geography)
- Savings tracking: Negotiated vs. baseline (validated by Finance)
- Target: 5-8% addressable spend savings annually
- Maverick spend: < 3% target (non-contracted, non-PO)

12. Ethics & Compliance

12.1 Conflicts of Interest

- Annual disclosure: Vendor relationships (family, financial, prior employment)
- Recusal: Required if conflict exists (Procurement manages alternate)
- Gifts: Zero tolerance from vendors (see Ethics Policy)

12.2 Anti-Corruption (FCPA / UK Bribery Act)

- Due diligence: All vendors (sanctions, adverse media, beneficial ownership)
- High-risk: Government-owned, intermediaries, high-corruption jurisdictions
- Clauses: Anti-bribery, audit rights, termination for corruption
- Training: Procurement + Requestors (annual)

12.3 Export Controls & Sanctions

- Screening: All vendors/entities against denied party lists (daily)
- Classification: ECCN determination for technical data/software
- Licenses: Procurement coordinates with Trade Compliance
- End-use certificates: Required for controlled items

12.4 Modern Slavery & Human Rights

- UK Modern Slavery Act / CA Transparency Act compliance
- Supplier Code of Conduct: Signed by all Tier 1/2 vendors
- Risk assessment: Geographic + industry inherent risk
- Audits: High-risk suppliers (third-party social audits)

13. Emergency Procurement

13.1 Emergency Definition

- Immediate threat to: Life safety, production outage, regulatory compliance, data breach
- Not: Poor planning, missed renewal, budget cycle

13.2 Emergency Process

- Verbal approval: VP + Finance (any one) + Security (if data access)
- Procurement executes: Best available terms, document justification
- Post-emergency: Formal RFP within 90 days; ratification at appropriate threshold

14. Metrics & Reporting

Metric	Target	Frequency	Audience
Contracted Spend %	> 95%	Monthly	CFO, CPO
Maverick Spend %	< 3%	Monthly	CFO, CPO
Diverse Spend %	15%	Quarterly	CFO, Board ESG
Vendor Risk Assessment	100% Tier 1	Quarterly	CISO, CPO, Legal
Contract Renewal On-Time	90%	Quarterly	CPO, Legal
Savings vs. Target	100%	Quarterly	CFO, CEO
Invoice Processing Time	< 5 days	Monthly	Finance, CPO
Vendor Consolidation	5% reduction	Annual	CPO, Category Leads

15. Related Policies & Documents

- Information Classification & Handling Policy
- IT Acceptable Use Policy
- Data Privacy & Protection Policy (DPA requirements)
- Security Incident Response Plan (vendor incidents)
- Business Continuity & Disaster Recovery Plan
- Expense & Reimbursement Policy
- Ethics & Code of Conduct
- Anti-Corruption & FCPA Policy
- Export Controls & Sanctions Policy
- Supplier Code of Conduct
- Standard Contract Templates (Legal)
- Vendor Risk Assessment Questionnaires (SIG Lite/Full)

16. Definitions

- **TCV:** Total Contract Value
- **MSA:** Master Services Agreement

- **SOW:** Statement of Work
- **RFP:** Request for Proposal
- **RFQ:** Request for Quotation
- **SIG:** Standardized Information Gathering (Shared Assessments)
- **DPA:** Data Processing Agreement
- **SCCs:** Standard Contractual Clauses
- **SLA:** Service Level Agreement
- **TCO:** Total Cost of Ownership
- **ESG:** Environmental, Social, Governance
- **MBE/WBE/VBE/LGBTBE/DOBE:** Minority/Women/Veteran/LGBT/Disability-Owned Business Enterprise
- **COI:** Certificate of Insurance
- **ECCN:** Export Control Classification Number
- **OFAC:** Office of Foreign Assets Control

17. Revision History

Version	Date	Author	Description
3.2	2024-02-01	Procurement + GC	Enhanced ESG, Tier 1 transition 180d, continuous monitoring, concentration risk
3.1	2023-08-15	Procurement	SIG questionnaire, subprocessors, contract repository (Ironclad)
3.0	2023-02-01	Procurement + GC	Major rewrite: tiered risk, mandatory clauses, diversity targets

---

END OF DOCUMENT